7 · Vulnerability disclosure policy

The vulnerability disclosure policy tells researchers, customers and suppliers how to report a vulnerability and what the manufacturer will do with it. Annex I Part II pt 5 requires a coordinated vulnerability disclosure (CVD) policy that is "put in place and enforce[d]", and pt 6 requires a reporting contact address. Publish it at the URL named in security.txt and Annex II pt 2, and file it in the technical documentation (Annex VII pt 2(b)).

At a glance

Item	Detail
Legal basis	Annex I Part II pts 2, 4, 5, 6, 7, 8; Art 13(6) (upstream reporting), 13(17) (non-automated contact); Annex II pt 2; Annex VII pt 2(b); Recital 76
Needed for	Every product. Part II applies from 11 Dec 2027, but Art 14 reporting has applied since 11 Sep 2026, so the intake must work now
Owner	PSIRT lead
Approver	Compliance lead, with legal for the safe harbour wording
When to create	Before placing on the market; now for products already in the field
When to update	Review yearly. Update on any change of contact, key, coordinator CSIRT or targets. Check security.txt quarterly and renew before Expires
Retention	Policy versions, case files, advisories and upstream reports: 10 years or the support period, whichever is longer (Art 13(13))
Feeds	Template 4, Annex VII pt 2(b); Template 6, Annex II pt 2; Template 8, the exploitation determination starts the Art 14 clock; Template 9, supplier notification duties

How to complete

1. Fill the field table for each product family: scope, channels, targets, coordinator CSIRT.
2. Set internal targets at or inside the reference figures shown. None of them is a legal deadline.
3. Adapt the policy text below. Decide with legal whether to include the safe harbour section.
4. Publish the policy at a stable URL and link it from the home page, security.txt and Annex II pt 2.
5. Publish security.txt at `/.well-known/security.txt` over HTTPS and sign it with the PSIRT OpenPGP key.
6. Staff every channel, monitor them daily and measure acknowledgement and response times.

Template

Policy fields

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Scope	Products, versions, companion apps, remote data processing and third-party components covered	Part II pt 6 ("as well as in third-party components")	All L2 SKUs and firmware versions in the field, including versions past end of support; L2 app; access-management cloud
Reporting contact	A contact address for reporting vulnerabilities; same as Annex II pt 2	Part II pt 6; Annex II pt 2	psirt@example.com
Web form	Allows anonymous submission; no third-party scripts or tracking	Recital 76; BSI TR-03183-3 (non-binding)	www.example.com/security/report
Non-automated channel	A monitored mailbox or phone line beside any automated tool	Art 13(17)	[+49 phone number], staffed [hours]

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Encryption	OpenPGP key for confidential reports	BSI TR-03183-3; ENISA kit (recommended)	www.example.com/security/psirt-pgp.asc
Acknowledgement target	No legal figure. BSI: non-automated response in 5 working days. Draft prEN 40000-1-3 reportedly caps it at 7 calendar days (second-hand, unpublished)	Part II pt 5	[5] working days
Detailed feedback target	No legal figure. BSI: 10 working days	Part II pt 5	[10] working days
Remediation	"Without delay" and "in relation to the risks posed". Not quantified in law; set internal targets by severity	Part II pt 2	[Critical: n days; High: n days; Medium: n days]
Disclosure timeline	Publish fixed vulnerabilities once an update is available; delay only "in duly justified cases". BSI default of 90 days, extendable once, is not law. Add an accelerated path for actively exploited vulnerabilities	Part II pt 4	[90] days or on fix release, whichever is first; exploited cases [accelerated]
Advisories	Human-readable advisory plus CSAF 2.0 with CVE and EUVD IDs, affected and fixed versions, severity, impact, remediation	Part II pt 4	Advisory index www.example.com/security/advisories

Field	What to enter	Basis	Example: L2 Smart Lock (illustrative)
Update delivery	Secure distribution; automatic where applicable; free of charge with advisory messages	Part II pts 7, 8	Signed over-the-air updates, free, with an in-app advisory
Upstream reporting	Report component vulnerabilities to the maintainer; share fixes where appropriate in machine-readable form	Art 13(6)	Report via the maintainer's CVD channel; record each action in the case file
Coordinator CSIRT	Name the CSIRT the manufacturer reports to and offer the anonymous route through it	Recital 76; Art 14(7)	Germany's coordinator CSIRT ([name and URL from ENISA's list of 4 Sep 2026])
Safe harbour	Optional. Legal decides scope and wording	ENISA kit section	Included, reviewed by legal [date]

Policy text

```
[MANUFACTURER] VULNERABILITY DISCLOSURE POLICY
Version [n], [date]. Owner: [PSIRT lead role].

1. Our commitment
We want to hear about vulnerabilities in our products. We investigate every
report, fix confirmed vulnerabilities without delay in relation to the risk
they pose, and provide security updates free of charge for the support
period.

2. Scope
This policy covers [products, versions, companion apps and online services],
including third-party components they contain. Out of scope: [e.g. corporate
IT systems; report those to [csirt contact]].

3. How to report
- Email: [psirt@domain] (encrypt with our key at [URL] if possible)
- Web form: [URL] (anonymous reports accepted)
```

- Phone: [number], [hours]
You may also report anonymously through [coordinator CSIRT name, URL].

4. Testing rules
Test only devices and accounts you own or are authorised to use. Do not access,
change or delete other people's data. Do not degrade our services. Stop and report as soon as you have shown the issue.

5. What to include
Product, model and version; description and impact; steps to reproduce or proof of concept; whether you believe it is being exploited; how to contact you.

6. What to expect
Acknowledgement within [n] working days. Detailed feedback within [n] working days. Status updates at least every [n] days until resolution.

7. Safe harbour [optional, confirm with legal]
If you act in good faith and follow this policy, we will not pursue legal action against you for your research, and we will say so if a third party asks. [Limits and jurisdictions.]

8. Disclosure
We publish an advisory once a fix is available, normally within [n] days of your report. We may delay publication only where duly justified, until users have been able to update. Actively exploited vulnerabilities follow an accelerated timeline. We agree the date with you before publishing.

9. Third-party components and coordination
We report vulnerabilities in components to their maintainers and share fixes where appropriate. Where needed we coordinate with [coordinator CSIRT].

10. Recognition
With your consent we credit you in the advisory and at [hall-of-fame URL].

11. Data protection
We use your contact details only to handle your report. See [privacy notice URL].

security.txt

Field	Status	Rule	Basis
Contact	Mandatory	One line per channel, preferred method first	RFC 9116; ENISA kit section 3.1
Expires	Mandatory	At most 12 months ahead; renew before it lapses	RFC 9116; ENISA profile
Policy	Recommended	URL of this policy	ENISA profile
Preferred-Languages	Recommended	Languages the PSIRT reads	ENISA profile
Canonical	Recommended	The file's own HTTPS URL	ENISA profile
Encryption	Optional, recommended	URL of the PSIRT OpenPGP key	ENISA profile
Acknowledgments, CSAF	Optional	Hall of fame; CSAF provider metadata	BSI TR-03183-3 section 4.2.8

Example: L2 Smart Lock (illustrative). Sign the file with the PSIRT key.

```
# https://www.example.com/.well-known/security.txt
Contact: mailto:psirt@example.com
Contact: https://www.example.com/security/report
Contact: tel:+49-[number]
Expires: 2027-10-30T23:59:59.000Z
Encryption: https://www.example.com/security/psirt-pgp.asc
Preferred-Languages: en, de
Canonical: https://www.example.com/.well-known/security.txt
Policy: https://www.example.com/security/cvd-policy
Acknowledgments: https://www.example.com/security/hall-of-fame
CSAF: https://www.example.com/.well-known/csaf/provider-metadata.json
```

The ENISA SME Vulnerability Kit cited here is an October 2026 consultation draft, and prEN 40000-1-3 is unpublished.

Common mistakes

- An expired security.txt. Expired contacts head ENISA's common-mistakes list.
- A published policy nobody staffs or monitors.
- An intake that refuses reports about third-party components (Part II pt 6).

- BSI or draft-standard figures written into the policy as legal deadlines, or targets that are never measured.
- Treating every bug-bounty finding as actively exploited, or the reverse. Art 3(42) requires reliable evidence of malicious exploitation.

Template 7 · v1.0 · 31 Oct 2026 · Not legal advice; confirm wording against the Official Journal text before use.